

Marco integrativo GQM + PRAGMATIC para indicadores CVSS v4.0 a nivel nacional (España)

1. Propósito del marco

Este marco integra la metodología Goal–Question–Metric (GQM) con los criterios PRAGMATIC para definir, evaluar y gobernar indicadores basados en CVSS v4.0 aplicados al contexto nacional y territorial de España.

Su misión es garantizar trazabilidad explícita desde los objetivos estratégicos de país (estrategia nacional de ciberseguridad, NIS2, protección de infraestructuras críticas) hasta los datos técnicos de vulnerabilidades, reduciendo la distancia entre “CVE 9.8” y “¿por qué esto importa al Consejo de Ministros?” [web:1][web:22][web:7][web:13]

2. Resumen conceptual

El marco se apoya en tres capas:

- Capa de objetivos (Goal): objetivos nacionales y sectoriales en materia de ciberseguridad y resiliencia (p. ej. reducir la ventana de exposición de vulnerabilidades explotadas activamente en servicios esenciales). [web:7][web:12]
- Capa de preguntas (Question): cuestiones evaluativas que operacionalizan cada objetivo (p. ej. “¿con qué rapidez se mitigan las vulnerabilidades explotadas activamente en sanidad?”). [web:26][web:29]
- Capa de métricas (Metric): indicadores cuantitativos basados en CVSS v4.0 (Base, Threat, Environmental, Supplemental) que permiten responder de manera objetiva a las preguntas. [web:1][web:16][web:22]

Sobre esta estructura GQM se superpone la evaluación PRAGMATIC, que actúa como metamétrica de calidad para cada indicador. [web:21][web:24][web:27]

3. Objetivos GQM de referencia (nivel nacional)

A efectos del marco, proponemos cuatro objetivos marco G1–G4:

- **G1 – Minimizar la exposición intrínseca a vulnerabilidades críticas**
Reducir la densidad de sistemas expuestos a Internet con vulnerabilidades de alta severidad según CVSS v4.0. [web:1][web:22][web:12]
- **G2 – Reducir la ventana de exposición explotable**
Acortar el tiempo entre la publicación/divulgación de una vulnerabilidad y su mitigación efectiva, con foco en vulnerabilidades con métrica Threat que indique explotación activa o masiva. [web:1][web:7][web:13]
- **G3 – Proteger servicios esenciales y funciones críticas**
Priorizar la mitigación en activos cuya indisponibilidad tenga impacto alto en seguridad de la vida humana, orden público o estabilidad económica, mediante el uso de métricas Environmental y Supplemental. [web:1][web:10][web:12]
- **G4 – Asegurar alineamiento regulatorio y capacidad de reporting**
Garantizar que los indicadores derivados de CVSS permiten cumplir con NIS2, esquemas nacionales y requerimientos de reporte a ENISA, CSIRTs y autoridades nacionales. [web:7][web:13][web:12]

G1 – Minimizar la exposición intrínseca a vulnerabilidades críticas

Reducir la densidad de sistemas expuestos a Internet con vulnerabilidades de alta severidad según CVSS v4.0. [web:1][web:22][web:12]

G2 – Reducir la ventana de exposición explotable

Acortar el tiempo entre la publicación/divulgación de una vulnerabilidad y su mitigación efectiva, con foco en vulnerabilidades con métrica Threat que indique explotación activa o masiva. [web:1][web:7][web:13]

G3 – Proteger servicios esenciales y funciones críticas

Priorizar la mitigación en activos cuya indisponibilidad tenga impacto alto en seguridad de la vida humana, orden público o estabilidad económica, mediante el uso de métricas Environmental y Supplemental. [web:1][web:10][web:12]

G4 – Asegurar alineamiento regulatorio y capacidad de reporting

Garantizar que los indicadores derivados de CVSS permiten cumplir con NIS2, esquemas nacionales y requerimientos de reporte a ENISA, CSIRTs y autoridades nacionales. [web:7][web:13][web:12]

Cada objetivo se despliega en preguntas y métricas específicas (ver plantillas en la sección 6 y el fichero de matriz PRAGMATIC). [web:26][web:29]

4. Metodología GQM aplicada a CVSS v4.0

La aplicación de GQM sigue las etapas clásicas, adaptadas a un contexto nacional:

1.

Definir objetivos (Goal):

Se formulan objetivos en lenguaje de negocio y de política pública, no técnico (“reducir X”, “garantizar Y”), vinculados a estrategias nacionales, a NIS2 y a planes sectoriales. [web:7][web:12]

2.

Derivar preguntas (Question):

Se redactan preguntas que, si se respondieran de manera objetiva, permitirían evaluar el grado de consecución del objetivo (por ejemplo: “¿cuál es la proporción de servicios esenciales que mantienen vulnerabilidades con vector de ataque remoto y Threat=Active más de 30 días?”). [web:26][web:29]

3.

Diseñar métricas (Metric):

Se define para cada pregunta un conjunto mínimo de métricas, apoyadas en:

4. CVSS Base (explotabilidad e impacto intrínseco).

5. CVSS Threat (explotación real, disponibilidad de exploit).

6. CVSS Environmental (criticidad de activos, controles compensatorios, requisitos de disponibilidad).

7.

CVSS Supplemental (impacto en seguridad física, productos de seguridad, etc.). [web:1][web:16]
[web:22][web:18]

8.

Validar con PRAGMATIC:

Cada métrica se somete a los nueve criterios PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable) valorados en una escala numérica común. [web:21][web:24][web:27]

9.

Iterar y racionalizar:

Métricas con baja puntuación PRAGMATIC se revisan, simplifican o eliminan para evitar cuadros de mando obesos con indicadores inútiles. [web:27]

Definir objetivos (Goal):

Se formulan objetivos en lenguaje de negocio y de política pública, no técnico (“reducir X”, “garantizar Y”), vinculados a estrategias nacionales, a NIS2 y a planes sectoriales. [web:7][web:12]

Derivar preguntas (Question):

Se redactan preguntas que, si se respondieran de manera objetiva, permitirían evaluar el grado de

consecución del objetivo (por ejemplo: “¿cuál es la proporción de servicios esenciales que mantienen vulnerabilidades con vector de ataque remoto y Threat=Active más de 30 días?”). [web:26][web:29]

Diseñar métricas (Metric):

Se define para cada pregunta un conjunto mínimo de métricas, apoyadas en:

CVSS Supplemental (impacto en seguridad física, productos de seguridad, etc.). [web:1][web:16][web:22][web:18]

Validar con PRAGMATIC:

Cada métrica se somete a los nueve criterios PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable) valorados en una escala numérica común. [web:21][web:24][web:27]

Iterar y racionalizar:

Métricas con baja puntuación PRAGMATIC se revisan, simplifican o eliminan para evitar cuadros de mando obesos con indicadores inútiles. [web:27]

5. Criterios PRAGMATIC para métricas CVSS

Los criterios se interpretan en clave de gobernanza nacional:

- Predictivo: grado en que la métrica permite anticipar situaciones futuras (p. ej. incidentes graves, sanciones, interrupciones de servicios esenciales).
- Relevante: cercanía de la métrica a las preocupaciones reales de decisores políticos y reguladores nacionales.
- Accionable: claridad y rapidez con la que la métrica sugiere decisiones específicas (financiación, regulación, inspecciones, campañas de parcheo).
- Genuino: resistencia de la métrica a la manipulación o “gaming” por parte de los actores medidos.
- Significativo: facilidad de comprensión y valor explicativo para audiencias no técnicas.
- Preciso (Accurate): calidad de los datos subyacentes y robustez de los métodos de cálculo.
- Oportuno (Timely): capacidad de actualizar la métrica con la frecuencia necesaria para que siga siendo útil.
- Independiente: grado en que la métrica no se auto-justifica ni depende de decisiones arbitrarias de la propia función que la produce.
- Rentable (Cost-effective): relación coste/beneficio de obtener y explotar la métrica a escala nacional. [web:21][web:24][web:27]

Cada criterio se puntúa típicamente en una escala 0–5 o 1–5. El metapuntaje PRAGMATIC de una métrica es la suma o media ponderada de los nueve criterios, lo que permite compararlas y priorizarlas. [web:21][web:24][web:27]

6. Estructura GQM + PRAGMATIC por indicador

Cada indicador CVSS a nivel nacional se documentará con la siguiente ficha:

- Código de métrica: identificador único (p. ej. M-G1-EXP-01).
- Objetivo GQM asociado: referencia al objetivo G1-G4.
- Pregunta(s) GQM: listado de preguntas a las que responde.
- Definición operacional de la métrica:
- Fórmula.
- Fuente(s) de datos (CSIRTs, EUVD, registros nacionales, catálogos de activos). [web:7][web:13][web:22]
- Dimensiones de segmentación (sector, CCAA, tipo de organismo).
- Parámetros CVSS utilizados: Base/Threat/Environmental/Supplemental, versión, referencia a la especificación. [web:1][web:16][web:22]
- Escala y unidad: porcentaje, número absoluto, días, índice.
- Periodicidad: mensual, trimestral, anual.
- Evaluación PRAGMATIC: tabla 9×1 con puntuaciones y metapuntaje. [web:21][web:24][web:27]
- Riesgos y limitaciones: sesgos, dependencias, riesgos de manipulación.

7. Gobernanza y ciclo de vida del marco

- Custodia: El marco se mantiene a nivel nacional (por ejemplo, en un organismo tipo INCIBE / NCC-ES en coordinación con ministerios competentes). [web:12][web:22]
- Actualización: Revisión anual o cuando haya cambios relevantes (actualización CVSS, nuevas obligaciones europeas, incidentes significativos). [web:1][web:7][web:13]
- Interoperabilidad: El marco se alinea con EUVD, NIS2 y guías ENISA, así como con exigencias internas de reporting de cada ministerio. [web:7][web:13]
- Formación: Difusión del marco a CSIRTs sectoriales, responsables de ciberseguridad en CCAA y operadores de servicios esenciales, para asegurar un uso consistente. [web:9][web:22]

Este documento se debe leer junto con:

- La “Matriz de Evaluación PRAGMATIC Completa”.
- El “Mapeo detallado de preguntas a requisitos normativos”.
- Las plantillas de Excel (IGM y ROI) y PowerPoint (reporte ejecutivo).